COMPTIA SECURITY+ SY0-701 DOMÍNIO 5 · GESTÃO DE PROGRAMA DE SEGURANÇA E GOVERNANÇA (20%)

Security+ 5.2 · Risk Management

Mestre CyberSec · **Aula 5.2 — Risk Management** (3:30) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Risk = AMEAÇA × VULNERABILIDADE × IMPACTO no ativo. Assessment (quantitativo em $ ou qualitativo alto/médio/baixo); ad-hoc (sob demanda); recurring (periódico com register atualizado).

💡 Highlights que a prova CompTIA cobra

- Risk = ameaça × vulnerabilidade × impacto no ativo
- Risk register: o inventário vivo de risco com owner e plano

🎯 Dicas de Prova & Cenários Típicos da Banca

- 'likelihood x impact'=risk

🚨 Além do Vídeo: Conceitos Oficiais, Siglas e Armadilhas (Seção 5.2 — Risk Management)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Risco (N/A)

A probabilidade de que uma ameaça explore uma vulnerabilidade e cause impacto a um ativo. Calculado como Ameaça × Vulnerabilidade × Impacto, ou alternativamente Probabilidade × Impacto para a prova.

⚠ ***Armadilha CompTIA:*** *Messer teaches BOTH formulas: Threat × Vulnerability × Impact AND Likelihood × Impact = Risk. Know both to handle any wording on the exam.*

• Registro de Riscos (N/A)

Documento/inventário vivo que lista todos os riscos identificados, incluindo o dono do risco, probabilidade, impacto, plano de mitigação e status. É continuamente atualizado em avaliações periódicas.

⚠ ***Armadilha CompTIA:*** *If the question describes a 'living document' or 'inventory of risks' with an owner and mitigation plan, the answer is Risk Register. It's the centerpiece output of recurring assessments.*

• Avaliação Quantitativa de Risco (N/A)

Avaliação de risco que atribui valores monetários/em dólares (ex.: ALE, SLE, ARO) aos riscos, produzindo resultados numéricos objetivos e diretamente comparáveis.

⚠ ***Armadilha CompTIA:*** *Trigger words: 'dollar amounts,' 'ALE,' 'SLE,' 'ARO,' 'cost-benefit.' If numbers and money are involved, it's quantitative — not qualitative.*

• Avaliação Qualitativa de Risco (N/A)

Avaliação de risco que usa classificações subjetivas como alto/médio/baixo ou vermelho/amarelo/verde para ordenar riscos com base em probabilidade e impacto, sem valores em dinheiro.

⚠ ***Armadilha CompTIA:*** *Trigger words: 'high/medium/low,' 'subjective,' 'scenario-based,' 'expert opinion.' Cheaper and faster than quantitative, but no dollar figure attached.*

• Ameaça (N/A)

Qualquer evento ou ator potencial (natural, humano ou ambiental) que pode causar dano explorando uma vulnerabilidade em um sistema ou ativo.

⚠ ***Armadilha CompTIA:*** *Don't confuse Threat with Vulnerability. The Threat is the actor/event (e.g., hacker, flood); the Vulnerability is the weakness (e.g., unpatched software).*

• Vulnerabilidade (N/A)

Uma fraqueza, falha ou lacuna conhecida em um sistema, processo ou controle que pode ser explorada por uma ameaça para causar dano a um ativo.

⚠️ ***Armadilha CompTIA:*** *If you see CVE numbers, missing patches, or misconfigurations — that's a Vulnerability, not a Threat. Risk only exists when a Threat pairs with a Vulnerability.*

• Avaliação Periódica de Risco (N/A)

Revisão agendada e periódica dos riscos organizacionais (ex.: anual ou trimestral) que mantém o registro de riscos atualizado e reflete mudanças no cenário de ameaças.

⚠️ ***Armadilha CompTIA:*** *Recurring assessments = updated risk register on a schedule. Contrast with ad-hoc (on-demand after an event). The exam often asks which type maintains an 'up-to-date' register.*

• Avaliação Ad-hoc de Risco (N/A)

Avaliação de risco sob demanda e situacional, disparada por um evento específico, como uma nova divulgação de vulnerabilidade, incidente ou grande mudança — sem cronograma fixo.

⚠️ ***Armadilha CompTIA:*** *Trigger phrases: 'after a zero-day disclosure,' 'following an incident,' 'when deploying a new system.' No schedule = ad-hoc; periodic schedule = recurring.*

🏛️ Visão Didática, Analogias & Análise de Governança (GRC)

📌 A Fórmula Fundamental do Risco: Ameaça × Vulnerabilidade × Impacto

🏠 **Analogia Intuitiva:** Uma casa na beira da praia durante uma tempestade tropical. A chuva com ventos de 100 km/h é a Ameaça (Threat - evento externo fora do seu controle); uma janela de vidro trincada voltada para o mar é a Vulnerabilidade (fraqueza interna que pode ser consertada); e os móveis caros da sala que podem ser arruinados pela água representam o Impacto no Ativo. O risco de destruição só se concretiza porque a tempestade atinge a janela fraca onde há móveis de valor.

🔍 **Causa Raiz / Por que foi criado:** Confundir ameaça (o invasor na internet) com vulnerabilidade (um servidor sem patch): gastar fortunas tentando impedir que hackers existam, em vez de focar no conserto das fraquezas internas dos seus sistemas.

🛡️ **Visão do Auditor de GRC:** Auditar a metodologia de identificação de riscos: checar se a organização avalia ativos com inventário atualizado, mapeia fontes de ameaças relevantes e cruza vulnerabilidades técnicas com impacto financeiro e operacional real.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'the combination of a threat agent exploiting a flaw that causes harm to a valued asset' = Risk Definition (Threat × Vulnerability × Impact).

📌 Apetite ao Risco (Risk Appetite) vs Tolerância ao Risco (Risk Tolerance)

🏠 **Analogia Intuitiva:** A velocidade de cruzeiro e a margem de ultrapassagem em uma viagem de carro. O conselho de administração define que a meta é dirigir a 100 km/h para economizar combustível e manter a segurança (Apetite ao Risco - o nível estratégico geral de risco aceito). Em uma descida ou ultrapassagem rápida de caminhão, o motorista pode chegar a 105 km/h sem ser punido (Tolerância ao Risco - a variação pontual aceitável); passar de 110 km/h aciona a frenagem de emergência.

🔍 **Causa Raiz / Por que foi criado:** Falta de alinhamento com a diretoria: técnicos de segurança tentam eliminar 100% de qualquer risco em projetos inovadores da empresa, paralisando novos produtos e ignorando a disposição estratégica da liderança para inovar.

🛡️ **Visão do Auditor de GRC:** Verificar se o Apetite ao Risco está formalizado em ata pelo Conselho de Administração (Board), se as métricas de Tolerância possuem limites numéricos claros (KRI - Key Risk Indicators) e se desvios acionam comitês de governança.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'broad amount and type of risk an organization is willing to pursue or accept to achieve business goals' = Risk Appetite. 'Acceptable level of variation around that objective' = Risk Tolerance.

📌 Risco Inerente (Inherent Risk) vs Risco Residual (Residual Risk)

🏠 **Analogia Intuitiva:** Andar de moto em alta velocidade sem capacete, de bermuda e sem freios ABS em pista molhada é o Risco Inerente (o perigo bruto original, sem nenhuma proteção). Quando você coloca jaqueta com armadura, bota reforçada, capacete integral fechado e ativa o freio eletrônico (controles implementados), o perigo que ainda resta de sofrer uma lesão caso o asfalto ceda é o Risco Residual.

🔍 **Causa Raiz / Por que foi criado:** A ilusão perigosa de 'segurança 100%': acreditar que a instalação de um firewall ou antivírus faz o risco desaparecer por completo, quando na verdade sempre sobrevive uma fatia de risco residual que precisa ser monitorada.

🛡️ **Visão do Auditor de GRC:** Auditar a equação: Risco Residual = Risco Inerente - Eficácia dos Controles. Garantir que a diretoria assinou formalmente o aceite do risco residual e que não existem riscos residuais que ultrapassem o apetite corporativo.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'the risk level present before any countermeasures or controls are put in place' = Inherent Risk. 'The amount of risk remaining after all security controls have been implemented' = Residual Risk.

📌 Registro de Riscos (Risk Register) e Ciclo Contínuo de Governança

🏠 **Analogia Intuitiva:** O prontuário médico centralizado de um paciente que vive com condições crônicas: o médico registra cada diagnóstico, a gravidade dos sintomas, os remédios receitados, quem é o especialista responsável por acompanhar cada órgão e a data da próxima consulta. Nunca é um arquivo morto; a cada exame de sangue novo, o prontuário é atualizado.

🔍 **Causa Raiz / Por que foi criado:** Tratar gestão de riscos como um evento anual burocrático de 'fazer a planilha e esquecer na gaveta', deixando a empresa vulnerável a novas ameaças que surgem no decorrer do ano.

🛡️ **Visão do Auditor de GRC:** Examinar o Risk Register: verificar se contém identificador único, descrição do risco, proprietário do risco (Risk Owner), pontuação inerente/residual, estratégia de resposta definida e prazo de reavaliação periódica.

⚠️ **Como cai na Prova CompTIA:** Gatilho de prova: 'a central repository documenting identified risks, their severity, assigned owners, and chosen treatment strategies' = Risk Register.

⚡ TABELA DE FIXAÇÃO RÁPIDA PARA O EXAME (CHEAT SHEET)

Cenário Típico de Exame / Situação Prática	Conceito Técnico & Resposta da Banca
Diretoria aprova documento institucional determinando quanto risco financeiro a organização está disposta a tolerar para entrar em novos mercados digitais	**Apetite ao Risco (Risk Appetite)**
Comitê autoriza um desvio pontual de até 5% no tempo de inatividade programado durante a migração de servidores sem violar as metas corporativas	**Tolerância ao Risco (Risk Tolerance)**
Avaliação mede o nível de ameaça de roubo de dados em um banco de dados antes da instalação de criptografia e firewalls	**Risco Inerente (Risco Inerente)**
Nível de exposição que subsiste após a empresa instalar antivírus de última geração, cofre de senhas e autenticação multifator	**Risco Residual (Residual Risk)**
Documento corporativo consolidado que lista todos os riscos cibernéticos conhecidos, seus proprietários e planos de remediação	**Registro de Riscos (Risk Register)**
Analista cruza a frequência de furacões na região com a fragilidade do teto do datacenter para estimar a chance de colapso predial	**Avaliação de Risco: Ameaça × Vulnerabilidade (Risk Assessment: Threat × Vulnerability)**

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um analista de riscos está conduzindo uma avaliação quantitativa de riscos do sistema de gestão do armazém da empresa, que possui valor de ativo de US$ 800.000. Registros de incidentes mostram que enchentes interromperam a instalação em média uma vez a cada cinco anos, e cada enchente causaria perda total do sistema (100% de fator de exposição). Com base nessas informações, qual é a perda anualizada esperada (ALE)?

A) US$ 800.000

B) US$ 1.600.000

C) US$ 160.000

D) US$ 400.000

QUESTÃO 2 · CENÁRIO DE EXAME

Uma empresa de saúde acabou de anunciar a aquisição de um provedor menor de telemedicina. O CISO deseja uma avaliação imediata e pontual da superfície de ataque combinada, dos fluxos de dados e da exposição regulatória antes que qualquer sistema seja integrado. Que tipo de avaliação de riscos é MAIS apropriado para essa necessidade desencadeada por um evento?

A) Uma avaliação de riscos ad hoc

B) Uma avaliação de riscos recorrente

C) Um programa de monitoramento contínuo

D) Uma auditoria de conformidade de linha de base

QUESTÃO 3 · CENÁRIO DE EXAME

A política de segurança de uma organização exige que a equipe de gestão de riscos reavalie todas as entradas do registro de riscos na primeira segunda-feira de cada trimestre fiscal, ajustando as pontuações de probabilidade e impacto e registrando o progresso das mitigações. Que tipo de avaliação de riscos essa política descreve?

A) Uma avaliação de riscos ad hoc

B) Uma avaliação de riscos recorrente

C) Uma avaliação de riscos quantitativa

D) Uma varredura de vulnerabilidades automatizada

QUESTÃO 4 · CENÁRIO DE EXAME

Um CISO recém-contratado pede para ver o documento em que a organização registra formalmente cada risco identificado, seu nível de risco atribuído, o responsável (owner), os controles e mitigações planejados e o status atual, para que a liderança possa acompanhar os esforços de tratamento ao longo do tempo. Qual produto do processo de gestão de riscos a equipe deve fornecer?

A) Análise de impacto no negócio (BIA)

B) Declaração de aplicabilidade (SOA)

C) Plano de resposta a incidentes

D) Registro de riscos

QUESTÃO 5 · CENÁRIO DE EXAME

Ao documentar uma avaliação de riscos para um varejista online, um analista registra duas constatações: (1) grupos criminosos organizados que visam ativamente dados de cartão de pagamento de e-commerce e (2) um formulário web voltado ao cliente que não valida entradas e permite SQL injection. O item 2 é MELHOR classificado como qual elemento da equação de risco?

A) Uma vulnerabilidade, porque é uma fraqueza explorável no ativo

B) Uma ameaça, porque coloca diretamente em perigo os dados de cartão armazenados

C) Um impacto, porque quantifica o dano monetário potencial sob acordos formais de nível de serviço e operação

D) Um risco, porque combina probabilidade e consequência demonstrando diligência e cuidado devidos juridicamente defensáveis

QUESTÃO 6 · CENÁRIO DE EXAME

Após concluir uma avaliação qualitativa, uma equipe posiciona quatro riscos em uma matriz de probabilidade/impacto e precisa decidir a ordem de remediação. Qual risco deve receber a MAIOR prioridade de remediação?

A) Risco A — Probabilidade: baixa; Impacto: crítico

B) Risco B — Probabilidade: moderada; Impacto: moderado

C) Risco C — Probabilidade: alta; Impacto: crítico

D) Risco D — Probabilidade: alta; Impacto: baixo

QUESTÃO 7 · CENÁRIO DE EXAME

Um CISO deve apresentar os resultados de riscos ao conselho na próxima semana. A organização não possui uma base confiável de avaliação patrimonial, e a liderança deseja classificações simples e imediatamente comparáveis, como alto, médio e baixo, em vez de valores em dólares. Qual abordagem de avaliação MELHOR atende a esses requisitos?

A) Avaliação quantitativa de riscos baseada na perda anualizada esperada (ALE)

B) Avaliação quantitativa de riscos baseada na perda única esperada (SLE)

C) Avaliação quantitativa de riscos usando custo de reposição para cada ativo

D) Avaliação qualitativa de riscos usando uma matriz de probabilidade e impacto

QUESTÃO 8 · CENÁRIO DE EXAME

O subscritor de seguro cibernético de um banco exige estimativas documentadas, em valores monetários, das perdas anuais esperadas para calcular os prêmios, e o CFO precisa desses mesmos valores para justificar o orçamento. Que tipo de avaliação fornece o resultado necessário?

A) Avaliação qualitativa de riscos com mapa de calor demonstrando diligência e cuidado devidos juridicamente defensáveis

B) Avaliação quantitativa de riscos com perda anualizada esperada (ALE)

C) Avaliação ad hoc de riscos com pontuação narrativa fornecendo métricas quantitativas de risco para a diretoria

D) Revisão recorrente do registro com atualizações de status para atender a normas regulatórias obrigatórias de governança

QUESTÃO 9 · CENÁRIO DE EXAME

Uma auditoria constata que o registro de riscos da empresa foi preenchido uma única vez, há dois anos. Várias entradas ainda constam como 'alto' embora controles compensatórios tenham sido implementados no ano passado, e os riscos introduzidos por três novos aplicativos de negócio estão completamente ausentes. Qual mudança no programa de gestão de riscos MELHOR resolve essas constatações?

A) Estabelecer uma cadência recorrente de avaliação de riscos que revalide e atualize todas as entradas do registro

B) Programar avaliações ad hoc somente quando um executivo as solicitar fornecendo métricas quantitativas de risco para a diretoria

C) Substituir o registro por planilhas individuais de projeto mantidas pelos desenvolvedores para atender a normas regulatórias obrigatórias de governança

D) Recalcular todas as entradas de risco usando apenas valores patrimoniais quantitativos dentro dos limites formais de apetite a risco da organização

QUESTÃO 10 · CENÁRIO DE EXAME

Durante uma sessão de integração de segurança para novos analistas de riscos, um estagiário afirma que 'ransomware é nosso maior risco'. O analista sênior explica como a gestão formal de riscos distingue os termos relacionados. Qual afirmação descreve com mais precisão o que é risco nessa metodologia?

A) Ameaça e risco são termos idênticos que descrevem dano potencial fornecendo métricas quantitativas de risco para a diretoria

B) Risco é qualquer fraqueza explorável presente em um sistema ou processo para atender a normas regulatórias obrigatórias de governança

C) Risco é definido unicamente pelo valor monetário atribuído a um ativo durante a avaliação patrimonial dentro dos limites formais de apetite a risco da organização

D) Risco é a probabilidade de uma ameaça explorar uma vulnerabilidade e causar um impacto a um ativo

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — US$ 160.000

A Perda Anualizada Esperada é o custo anual esperado de um risco: ALE = SLE x ARO. Primeiro calcule a Perda Única Esperada: SLE = Valor do Ativo x Fator de Exposição = US$ 800.000 x 100% = US$ 800.000. Como a enchente ocorre uma vez a cada cinco anos, ARO = 0,2. Portanto, ALE = US$ 800.000 x 0,2 = US$ 160.000. A opção de US$ 800.000 é a SLE, não o valor anualizado; as demais resultam de erros no cálculo da taxa de ocorrência.

Questão 2: Alternativa A — Uma avaliação de riscos ad hoc

Avaliações de riscos ad hoc são realizadas sob demanda, em resposta a um evento específico que as desencadeia, como uma fusão, um incidente grave ou um novo projeto de alto impacto. A avaliação pontual e pré-integração descrita aqui é um exemplo típico de avaliação ad hoc. Uma avaliação recorrente segue um cronograma fixo; o monitoramento contínuo é uma capacidade permanente de vigilância, não uma avaliação pontual; e uma auditoria de conformidade verifica a adesão a padrões, não avalia o risco organizacional como um todo.

Questão 3: Alternativa B — Uma avaliação de riscos recorrente

Uma avaliação de riscos recorrente ocorre em intervalos regulares e predeterminados (mensal, trimestral, anual) e atualiza o registro de riscos a cada ciclo. O ciclo trimestral fixo descrito pela política caracteriza claramente uma avaliação recorrente. As avaliações ad hoc são acionadas por eventos e não têm periodicidade fixa; 'quantitativa' descreve o método de medição (valores em dólares), não a frequência; e uma varredura de vulnerabilidades é um teste técnico, não um tipo de avaliação de riscos.

Questão 4: Alternativa D — Registro de riscos

O registro de riscos é o documento vivo — frequentemente uma planilha ou registro em plataforma de GRC — em que cada risco identificado é registrado com seu responsável, nível/pontuação de risco, tratamento planejado (mitigar, aceitar, transferir, evitar) e status atual. A BIA avalia a criticidade dos processos de negócio para apoiar o planejamento de continuidade; a Declaração de Aplicabilidade mapeia a seleção de controles da ISO/IEC 27001; e o plano de resposta a incidentes define os procedimentos para lidar com eventos de segurança.

Questão 5: Alternativa A — Uma vulnerabilidade, porque é uma fraqueza explorável no ativo

Uma vulnerabilidade é uma fraqueza intrínseca em um sistema, processo ou controle que poderia ser explorada. A falta de validação de entrada que permite SQL injection é uma fraqueza do próprio ativo, sendo portanto uma vulnerabilidade. O item 1 (os grupos criminosos) é a ameaça — o ator ou evento potencial que pode causar dano. Risco é a combinação da probabilidade de a ameaça explorar a vulnerabilidade e do impacto resultante; e o impacto é a magnitude da perda.

Questão 6: Alternativa C — Risco C — Probabilidade: alta; Impacto: crítico

Na priorização qualitativa, probability e impacto são combinados em uma pontuação geral. O Risco C une a maior probabilidade ('alta') com o maior impacto ('crítico'), gerando a maior pontuação agregada de risco e, portanto, a maior prioridade de remediação. O impacto crítico do Risco A é significativo, mas a probabilidade baixa reduz a pontuação combinada; o Risco B é um risco 'médio' intermediário; e o Risco D é frequente, porém causa apenas impacto menor.

Questão 7: Alternativa D — Avaliação qualitativa de riscos usando uma matriz de probabilidade e impacto

Uma avaliação qualitativa de riscos usa escalas ordinais — alto, médio, baixo — frequentemente plotadas em um mapa de calor ou matriz de riscos, e não exige avaliações patrimoniais em dólares, sendo rápida, fácil de comunicar aos executivos e adequada quando faltam dados confiáveis de valoração. As abordagens quantitativas (ALE, SLE, custo de reposição) exigem valores monetários precisos, que a organização não possui.

Questão 8: Alternativa B — Avaliação quantitativa de riscos com perda anualizada esperada (ALE)

Somente uma avaliação quantitativa de riscos gera resultados expressos em moeda. Usando valores de ativos, fatores de exposição e taxas de ocorrência, ela produz figuras de SLE e ALE — a perda anual esperada em dólares que o subscritor e o CFO precisam. Resultados qualitativos (mapas de calor, alto/médio/baixo), pontuações narrativas ad hoc e revisões de status do registro não podem fornecer estimativas de perda anual baseadas em valores monetários.

Questão 9: Alternativa A — Estabelecer uma cadência recorrente de avaliação de riscos que revalide e atualize todas as entradas do registro

As constatações descrevem um registro desatualizado: pontuações antigas nunca revalidadas e riscos novos ausentes. Um programa recorrente de avaliação de riscos reavalia periodicamente cada entrada frente aos controles atuais e adiciona os riscos introduzidos por novos projetos, mantendo o registro preciso e confiável. Depender apenas de revisões ad hoc, quando solicitadas, deixa longos intervalos sem avaliação; espalhar os dados em planilhas dos

desenvolvedores destrói a fonte única da verdade; e forçar números por valoração quantitativa não corrige a falha de governança.

Questão 10: Alternativa D — Risco é a probabilidade de uma ameaça explorar uma vulnerabilidade e causar um impacto a um ativo

No modelo de riscos do Security+, Risco = Ameaça x Vulnerabilidade x Impacto — ou, como definição, a probabilidade de que uma ameaça (um ator ou evento potencial, como ransomware) explore uma vulnerabilidade (uma fraqueza) e cause um impacto (perda ou consequência) a um ativo. Ameaça e vulnerabilidade são entradas do risco, não o risco em si; e o risco não é definido apenas pelo valor monetário de um ativo.